

Atividade registro semana 16 back-end

Atividade 1 — CORS

1. Explique com suas palavras por que o CORS é importante em uma API.

R: O CORS controla quais origens podem acessar uma API, ajudando na segurança.

2. Liste os três cabeçalhos de CORS estudados e diga a função de cada um.

R:

- Access-Control-Allow-Origin: define quais origens podem acessar.
 - Access-Control-Allow-Methods: define quais métodos HTTP são permitidos.
 - Access-Control-Allow-Headers: define quais cabeçalhos podem ser usados.
3. Explique como uma API pode permitir uma aplicação parceira e impedir uma origem não autorizada.

R: A API pode permitir o endereço da aplicação parceira no CORS e bloquear origens que não estejam autorizadas.

4. Explique um problema que pode acontecer se o CORS for configurado de forma incorreta.

R: Pode permitir acessos que deveriam ser bloqueados ou impedir aplicações autorizadas de acessar a API.

Atividade 2 — OAuth 2.0 e JWT

5. Explique a ideia do OAuth 2.0 no cenário bancário e cite os fluxos apresentados no material.

R: O OAuth 2.0 controla o acesso aos recursos sem precisar compartilhar diretamente a senha. Os fluxos são Authorization Code, Implicit, Password Credentials e Client Credentials.

6. Explique o que é armazenado no payload de um JWT e qual a função da signature.

R: O payload armazena informações sobre o usuário e suas permissões. A signature verifica se o token é válido e não foi alterado.

7. Descreva um fluxo simples para proteger uma operação financeira usando JWT.

R: O usuário faz login e recebe um JWT. Depois, envia o token na requisição. A API valida o token e permite ou nega a operação.

8. Cite medidas adicionais de segurança indicadas no material, como HTTPS e políticas de CORS.

R: Usar HTTPS, configurar o CORS corretamente e controlar a validade e as permissões dos tokens.

Atividade 3 — Investigando uma API com problema

9. Qual é a principal função de uma ferramenta de monitoramento?

R: Acompanhar o funcionamento da aplicação e identificar problemas.

10. Qual ferramenta apresentada no material é indicada para análise de logs em tempo real?

R: ELK Stack.

11. Qual a diferença entre log de acesso e log de erro?

R: O log de acesso registra as solicitações recebidas. O log de erro registra as falhas que aconteceram.

12. Como os logs podem ajudar a identificar tentativas de ataque?

R: Eles podem mostrar acessos suspeitos, IPs desconhecidos e várias tentativas de acesso.

13. Em um período de Black Friday, qual seria a primeira informação que você procuraria no monitoramento e por quê?

R: Eu verificaria o uso de CPU, memória e tráfego para saber se a API está sobrecarregada.

Miniquestionário de revisão

14. O que forma uma origem no CORS?

R: Protocolo, domínio e porta.

15. Qual cabeçalho define as origens permitidas?

R: Access-Control-Allow-Origin.

16. Qual é a diferença entre autenticação e autorização?

R: Autenticação identifica quem é o usuário. Autorização define o que ele pode acessar.

17. Quais são as três partes de um JWT?

R: Header, Payload e Signature.

18. Qual é a diferença entre monitoramento e análise de logs?

R: Monitoramento acompanha o sistema em funcionamento. Os logs registram os acontecimentos e erros do sistema.